Seguridad red

Mikel Egaña Aranguren

mikel-egana-aranguren.github.io

mikel.egana@ehu.eus

Universidad del País Vasco
Euskal Herriko Unibertsitatea
BILBOKO INGENIARITZA ESKOLA
ESCUELA DE INGENIERÍA DE BILBAO

Seguridad red

https://doi.org/10.5281/zenodo.4302267

https://github.com/mikel-egana-aranguren/EHU-SGSSI-01



Modelo OSI (Open Systems Interconnection)

Layer			Protocol data unit (PDU)	Function[27]
Host layers	7	Application	Data	High-level protocols such as for resource sharing or remote file access, e.g. HTTP.
	6	Presentation		Translation of data between a networking service and an application; including character encoding, data compression and encryption/decryption
	5	Session		Managing communication sessions, i.e., continuous exchange of information in the form of multiple back-and-forth transmissions between two nodes
	4	Transport	Segment	Reliable transmission of data segments between points on a network, including segmentation, acknowledgement and multiplexing
Media layers	3	Network	Packet, Datagram[28]	Structuring and managing a multi-node network, including addressing, routing and traffic control
	2	Data link	Frame	Transmission of data frames between two nodes connected by a physical layer
	1	Physical	Bit, Symbol	Transmission and reception of raw bit streams over a physical medium

https://en.wikipedia.org/wiki/OSI_model

TCP/IP

<table>
<tr><th>OSI Model</th><th colspan="6">TCP/IP Protocol Suite</th></tr>
<tr><td>Application
Presentation
Session</td><td>File Transfer

FTP
TFTP</td><td>Web Browser

HTTP</td><td>Email

SMTP
IMAP
POP3</td><td>Remote Login

Telnet</td><td>Name Resolution

DNS</td><td>IP Address

DHCP</td></tr>
<tr><td>Transport</td><td colspan="3">Transmission Control Protocol
TCP</td><td colspan="3">User Datagram Protocol
UDP</td></tr>
<tr><td>Network</td><td colspan="3">Internet Protocol
IP</td><td colspan="3">ARP
ICMP</td></tr>
<tr><td>Data Link</td><td colspan="2">Ethernet</td><td>Token Ring</td><td>FDDI</td><td colspan="2">WAN Protocols</td></tr>
<tr><td>Physical</td><td colspan="6">Copper Twisted Pair
Fiber Optic
Wireless</td></tr>
</table>

https://www.cdebyte.com/news/889

CIDR (Classless Inter-Domain Routing)

Asignar direcciones IP y enrutamiento en redes

Ejemplo: 192.168.1.0/24

red: 192.168.1.0 - 192.168.1.255 / host o subred 192.168.1.1 - 192.168.1.254

Mascara de red (Routers de una red a otra): 255.255.255.0

Captura de trafico de red

Laboratorio Wireshark

Segmentación de red

Segmentacion física

Segmentacion lógica mediante VLAN (Capa 2 OSI): agrupar dispositivos por funcionalidad

Segmentacion lógica mediante subredes (Capa 3 OSI): dividir una red en subredes más pequeñas (Rango de direcciones IP)

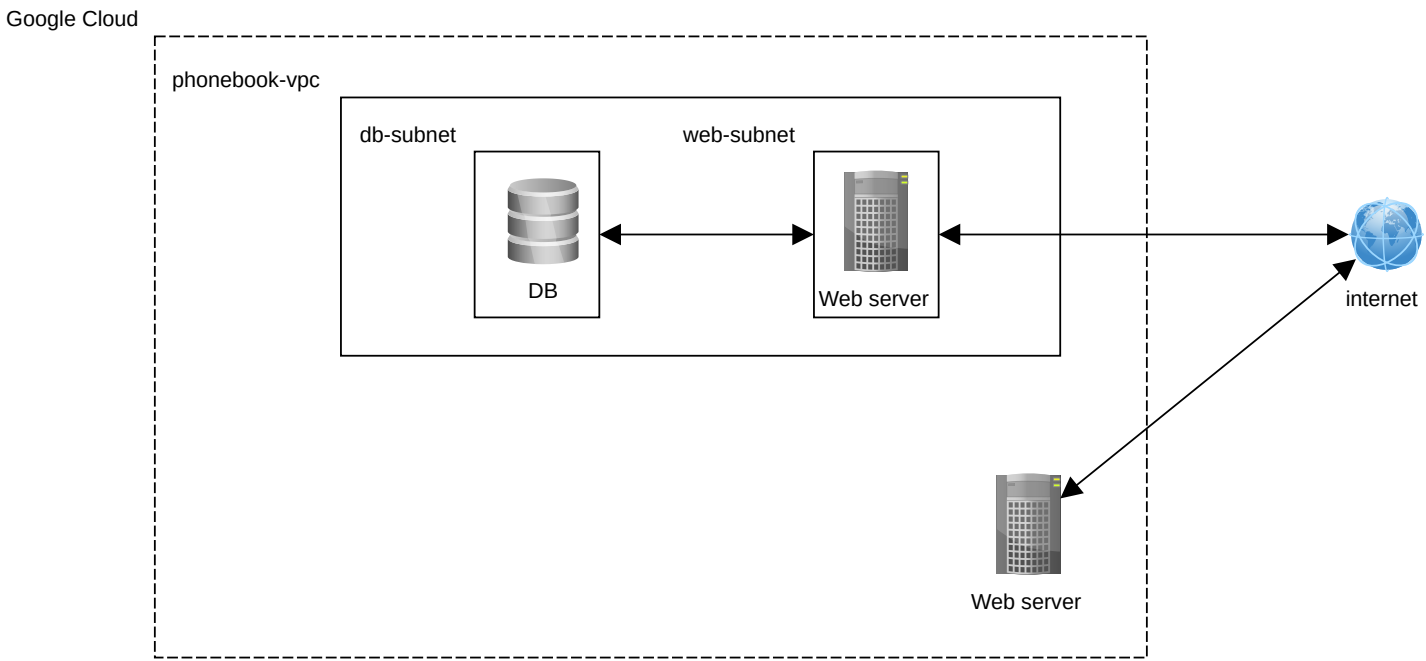
VPC (Virtual Private Cloud)

- Aislamiento: la red está lógicamente separada de otros usuarios de la nube
- Control de IPs: elegir los rangos de direcciones IP, subredes y tablas de rutas
- Gateways: gateways de internet y NAT controlan el tráfico entrante y saliente

VPC Google Cloud

Los objetivos de las reglas de firewall se definen mediante tags (ej. http-server, https-server) en vez de bloques CIDR

VPC Google Cloud



VPC Google Cloud

Laboratorio VPC Google Cloud

Firewall

Dispositivo/Software que controla el tráfico de entrada y salida de la red según reglas predefinidas

Las reglas se basan en diferentes criterios de seguridad

Firewall: funciones

Filtrado de paquetes: inspecciona cada paquete y lo compara con la reglas

Control de acceso: permite o deniega el acceso a servicios o protocolos

Registro y auditoria

NAT (Network Address Translation): multiples dispositivos comparten una única dirección IP pública

VPN (Virtual Private Network)*

Firewall: tipos

Packet Filtering Firewalls: Analizan solo los headers de los paquetes de red y permiten o bloquean el tráfico: IP de origen y destino, los puertos y los protocolos utilizados

Stateful Inspection Firewalls: Además de analizar los headers de los paquetes, realizan un seguimiento del estado de las conexiones de red. Pueden examinar el contenido de los paquetes y tomar decisiones basadas en el estado de la conexión

Firewall: tipos

Application Firewalls (Proxy Firewalls): Examinan el tráfico incluyendo protocolos de aplicación específicos, como HTTP, FTP o SMTP. Inspeccionan el contenido de los mensajes y aplican reglas de seguridad más avanzadas para detectar y bloquear amenazas específicas de las aplicaciones

Firewall: reglas filtrado generales

Bloquear paquetes que incluyan dirección de difusión (Broadcast) por ataques DoS

Bloquear paquetes de entrada con direccion fuente correspondiente a direcciones internas por suplantación de identidad (Spoofing)

Bloquear todos los paquetes de entrada con direcciones privadas referenciadas en RFC 1918 (Address Allocation for Private Internets)

Firewall: reglas filtrado generales

Bloquear los paquetes de entrada con direcciones fuente 127.0.0.1

Bloquear los paquetes del protocolo de control ICMP que en respuestas a peticiones Ping o Traceroute pueden dar información sobre la topología de la red interna

Firewall: reglas filtrado generales

Bloquear los paquetes ICMP Redirect que permiten modificar las tablas de enrutamiento de los routers

Bloquear todos los paquetes con un tamaño inferior al mínimo permitido o con valores inválidos en la cabecera

Firewall: puertos a bloquear

Conexion remota: Telnet (23), SSH (22), FTP (21)

RPC (Remote Procedure Call) y servicio NFS (Network File System) en Redes UNIX

HTTP, SSL, SMTP, POP, IMAP, DNS, LDAP en máquinas que no actúan como servidores

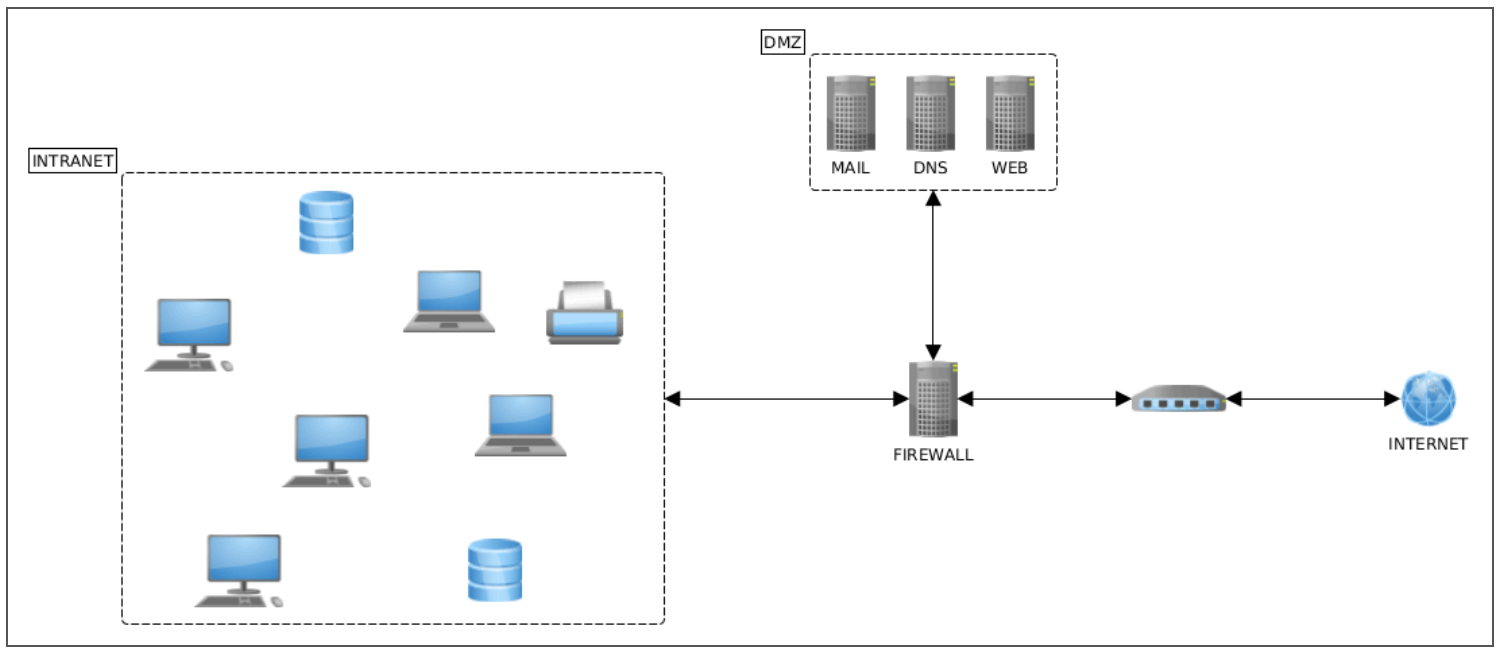
DMZ (Zona desmilitarizada)

Subred entre la intranet e internet donde se ubican los servicios públicos (correo, ftp, etc.) que quedan más expuestos a los problemas de seguridad

Se crea mediante el uso de uno o dos cortafuegos

Desde DMZ no se puede acceder directamente a la intranet

DMZ



Firewall

Laboratorio Firewall

NMap

Laboratorio NMap

Balanceador de carga

Distribuir el tráfico de red entre varios servidores para mejorar el rendimiento y la disponibilidad de los servicios

Intermediario entre los clientes y los servidores

Nivel aplicacion (HTTP) o nivel transporte (TCP/UDP)

Balanceador de carga

Distribucion de carga

Tolerancia a fallos

Escalabilidad

Control de sesiones

Optimización rendimiento

Balanceador de carga

Laboratorio Balanceador de carga

Proxy

Aplicación que actua de intermediario

El cliente hace las peticiones al proxy que se encarga de gestionarlas y enviarlas a los servidores remotos

Proporciona mayor seguridad durante la navegación porque el servidor desconoce quién se ha conectado realmente

Almacenar en caché las respuestas del servidor

Proxy HTTP(S)

Acceso a sitios web

Filtrado de contenido

Almacenamiento en caché

Proxy SOCKS

Proxy de nivel de transporte

Permite la conexión a través del protocolo SOCKS

Enrutamiento de tráfico de red

Anonimato

Proxy inverso

Lado servidor

Balanceo de carga

Protección de infraestructura

Proxy inverso

Laboratorio Proxy inverso (Squid)

IDS/IPS

IDS (Intrusion Detection System): sistema de detección de intrusos

IPS (Intrusion Prevention System): sistema de prevención de intrusos

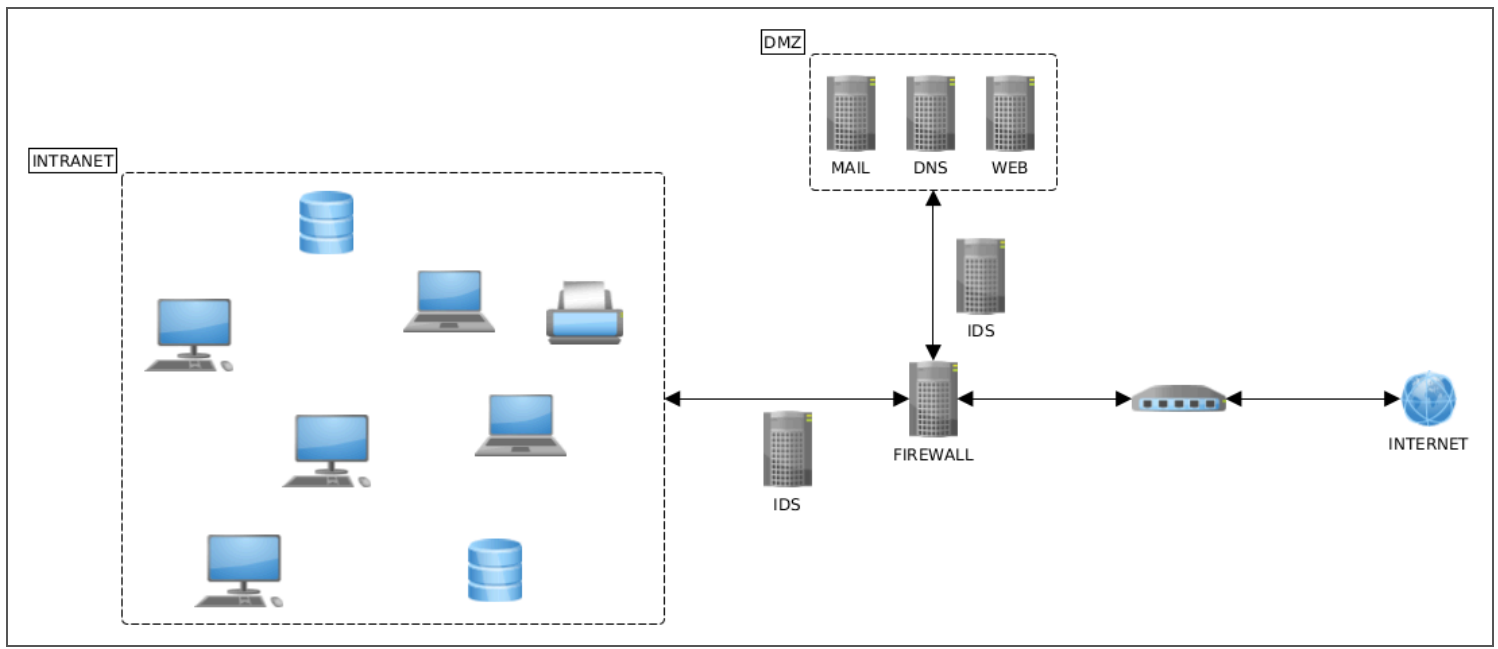
Host (HIPS, HIDS) o Network (NIPS, NIDS)

IDS/IPS

Heurística (Reglas): solo ataques conocidos. Algunos falsos positivos.

Anomalías: perfil de comportamiento. Ataques nuevos. Más falsos positivos.

IDS/IPS



IDS/IPS

SNORT

Suricata

Laboratorio Suricata

Honeypots

Sistema "señuelo" para que sea atacado

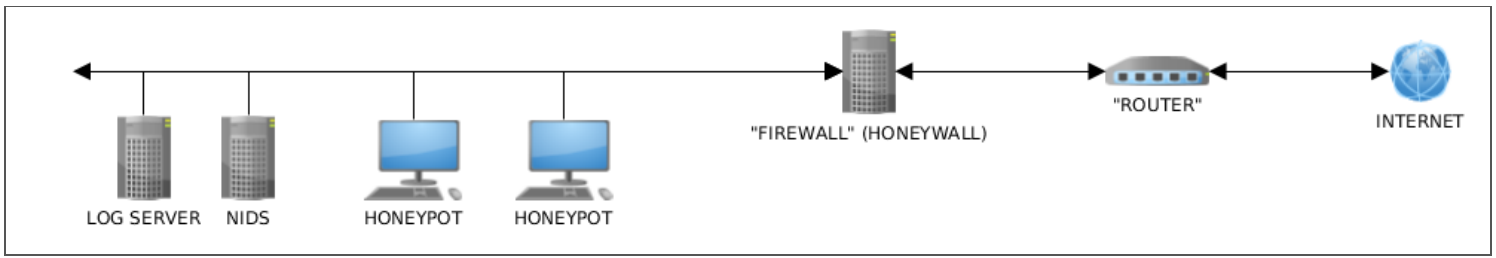
Honeynet: red de honeypots

Desviar los ataques

Obtener conocimiento de métodos de ataque

Obtener muestras de malware

Honeypots


LOG SERVER
NIDS
HONEYPOT
HONEYPOT
"FIREWALL" (HONEYWALL)
"ROUTER"
INTERNET

Redes Virtuales Privadas (VPN)

Red que usa una infraestructura no segura (Internet) para acceder de manera segura a una red interna

Usadas para la conexión remota a la red interna

VPN EHU

Redes Virtuales Privadas (VPN)

Permite:

- Autenticación y autorización mediante la gestión de usuarios, roles y permisos
- Integridad con el uso de funciones hash
- Confidencialidad puesto que la información viaja cifrada mediante algún algoritmo de encriptación
- No repudio porque los datos se transmiten firmados

Análisis de logs: Common Log Format

```
127.0.0.1 user-identifier frank [10/Oct/2000:13:55:36 -0700]
                                "GET /apache_pb.gif HTTP/1.0" 200 2326
```

- IP cliente
- Identificación cliente
- Nombre autenticación usuario
- Fecha/hora conexión

Análisis de logs: Common Log Format

```
127.0.0.1 user-identifier frank [10/Oct/2000:13:55:36 -0700]
                                "GET /apache_pb.gif HTTP/1.0" 200 2326
```

- Petición cliente
- Estado HTTP devuelto
- Bytes enviados

Ataques más comunes

Sniffing: Interceptación de la información que viaja por la red

Man in the middle: No sólo se intercepta la información, también se puede insertar y modificar a voluntad

Ataques más comunes

Hijacking: Robo de conexiones a un usuario autentificado en el sistema

- IP Hijacking
- Session hijacking
- DNS Hijacking
- ...

Ataques más comunes

Spoofing (Suplantación)

- IP Spoofing
- MAC Spoofing
- DNS Spoofing
- ...

Ataques más comunes

Denegación de Servicio (DoS): Se "satura" el hardware o software hasta que deja de responder

Ataque Distribuido de Denegación de Servicio (DDoS):

- Se realiza desde varias máquinas
- Una de ellas ejerce de master y coordina a las demás

Ataques más comunes

Ataque Distribuido de Denegación de Servicio (DDoS):

GitLab servers are being exploited in DDoS attacks in excess of 1 Tbps

Google mitigated the largest DDoS attack to date, peaking above 398 million rps